CONTROLLED PHISHING SIMULATION & HUMAN RISK ASSESSMENT

GoPhish • Kali Linux • Mailpit • Fictional test recipient

Assessment date: 8 November 2026

Prepared for: GRC / Information Security Management

Prepared by: Zainab Is'haq Musa/ C11/26/CGRCE/17229 GRC Analyst

Campaign	GRC Lab Simulation – November 2026
Test population	One fictional recipient: Lab User (lab.user@securebank.test)
Environment	Local Kali Linux laboratory; GoPhish with Mailpit SMTP capture

1. Executive Summary

A controlled phishing simulation was conducted in an isolated local laboratory using GoPhish to manage the campaign and Mailpit to capture test email. The exercise used one fictional recipient and a fictional security-awareness message and training page. The purpose was to observe the sequence of email delivery, opening, link interaction and a dummy-data submission event, then translate the observations into GRC risk measures and management actions.

The campaign evidence shows one email sent, one email opened and one link clicked. The final recipient detail in GoPhish records the recipient status as “Submitted Data”. Accordingly, the observed event counts are 1/1 for sending, opening, clicking and dummy-data submission. No email-reporting event was recorded (0/1). The final dashboard screenshot was captured while its counters were refreshing; therefore, the recipient-level status is used as the direct evidence of submission, and the report does not present the blank counters in that screenshot as zero.

These results demonstrate successful execution of the simulated phishing journey for the single test recipient. They do not establish organisation-wide susceptibility, prove that an awareness programme is ineffective, or demonstrate failure of enterprise email controls. The sample is intentionally small and fictional, and the exercise took place in a local lab.

2. Scope, Environment and Safety Controls

- Scope: one fictional test identity only; no real employees or external recipients were targeted.
- Tools: Kali Linux, GoPhish and Mailpit local SMTP capture.
- Campaign: “GRC Lab Simulation – November 2026”.
- Target identity: Lab User, lab.user@securebank.test; position recorded as Test Employee.
- Landing page: “GRC Training Page”, a fictional SecureBank GRC awareness page.
- Safety: the page instructed the test user not to enter passwords or personal information. The GoPhish landing-page configuration screenshot shows “Capture Submitted Data” unchecked; password capture was not enabled.
- Evidence: GoPhish campaign result screenshots and the uploaded laboratory screenshots. The exported CSV is retained as supporting evidence where available.

3. Observed Results and Risk Metrics

Metric	Observed events	Denominator	Rate
Email sent / delivery event	1	1	100%
Email opened	1	1 email sent	100%
Link clicked	1	1 email sent	100%
Dummy-data submission event	1	1 email sent	100%
Email reported	0	1 email sent	0%

3.1 Calculation Method

- Email open rate = emails opened ÷ emails sent × 100 = 1 ÷ 1 × 100 = 100%.
- Click-through rate (sent-email denominator) = unique link clicks ÷ emails sent × 100 = 1 ÷ 1 × 100 = 100%.
- Dummy-data submission rate (sent-email denominator) = submission events ÷ emails sent × 100 = 1 ÷ 1 × 100 = 100%.
- Click-to-submission conversion = submission events ÷ link clicks × 100 = 1 ÷ 1 × 100 = 100%.
- Email reporting rate = reported emails ÷ emails sent × 100 = 0 ÷ 1 × 100 = 0%.

Denominator note: rates are descriptive event ratios for a one-recipient test. The 100% rates must not be interpreted as statistically reliable estimates of employee behaviour. The “email sent” count is the GoPhish campaign event count; Mailpit confirms local SMTP capture, not delivery to an external production mailbox.

4. Phishing Risk Assessment

Finding	What the observation indicates	Risk interpretation / control implication
Email engagement	The test email was opened (1/1).	The message attracted attention in this test. This alone is not evidence of unsafe behaviour or control failure.
Link interaction	The simulated link was clicked (1/1).	Demonstrates that link verification and cautious handling should be reinforced.
Dummy-data submission	GoPhish recipient status shows “Submitted Data” (1/1).	The simulated journey reached its submission event. In a real

		attack, comparable behaviour could expose information; no real credentials were collected here.
Reporting	No report event was recorded (0/1).	The test did not record use of a reporting mechanism. Reinforce how and where suspicious messages should be reported.

5. Limitations and Interpretation

- The sample size was one fictional recipient. Results cannot be generalised to an organisation, business unit or workforce.
- The exercise was performed in a local laboratory, not against live enterprise mail infrastructure. It therefore does not test the effectiveness of production email gateways, endpoint controls or identity protections.
- Email-open tracking may be affected by email-client behaviour, image loading and automated processing.
- The recipient status “Submitted Data” is used as the submission evidence. The landing-page screenshot shows the Capture Submitted Data option unchecked and password capture was not enabled; consequently, the exercise did not collect or retain passwords.
- The campaign dashboard screenshot captured after the submission event was still refreshing and displayed blank event circles. The final recipient-level status is therefore cited separately rather than treating those blank circles as final counts.

6. Management Recommendations

1. **Strengthen multi-factor authentication (MFA).** Maintain MFA for critical systems and review coverage, particularly for remote access, privileged accounts and sensitive applications. MFA reduces the usefulness of a password alone if it is disclosed.
2. **Provide continuous, role-based awareness training.** Train staff to verify unexpected requests, inspect sender details and links, avoid sharing credentials, and use approved reporting channels. Reinforce learning with short refreshers rather than relying solely on annual training.

3. **Establish an accessible phishing-reporting process.** Provide a clear reporting route (for example, a report-phishing button or monitored security mailbox), define triage ownership and track response times.
4. **Conduct appropriately sized periodic simulations.** When authorised, use representative groups and a pre-approved scope. Compare results across campaigns and departments, and use trends rather than a single small sample to assess improvement.
5. **Review technical email protections.** Assess SPF, DKIM and DMARC alignment, anti-spoofing controls, URL and attachment inspection, and endpoint protections. Validate controls through approved testing.
6. **Integrate awareness into onboarding and governance.** Include phishing awareness and incident-reporting duties in new-starter induction, acceptable-use guidance and periodic policy acknowledgement.

7. Conclusion

The laboratory exercise demonstrated the configuration and execution of a controlled GoPhish campaign, use of Mailpit for local email capture, delivery of a fictional awareness message, interaction with a training page and recording of a recipient-level submission event. The observations provide a practical example of how GRC analysts can translate simulation events into measurable indicators and proportionate management recommendations. The findings should be treated as a technical demonstration only; a larger, approved and representative programme would be required to assess organisational human risk.

Appendix A – Screenshot Evidence

The following screenshots were selected from the laboratory evidence supplied in this conversation. Captions identify what each image supports and distinguish intermediate campaign status from final recipient status.



Figure 1. GoPhish campaign results during the simulation: 1 email sent, 1 opened, 1 link clicked, and no submission yet at this intermediate point.

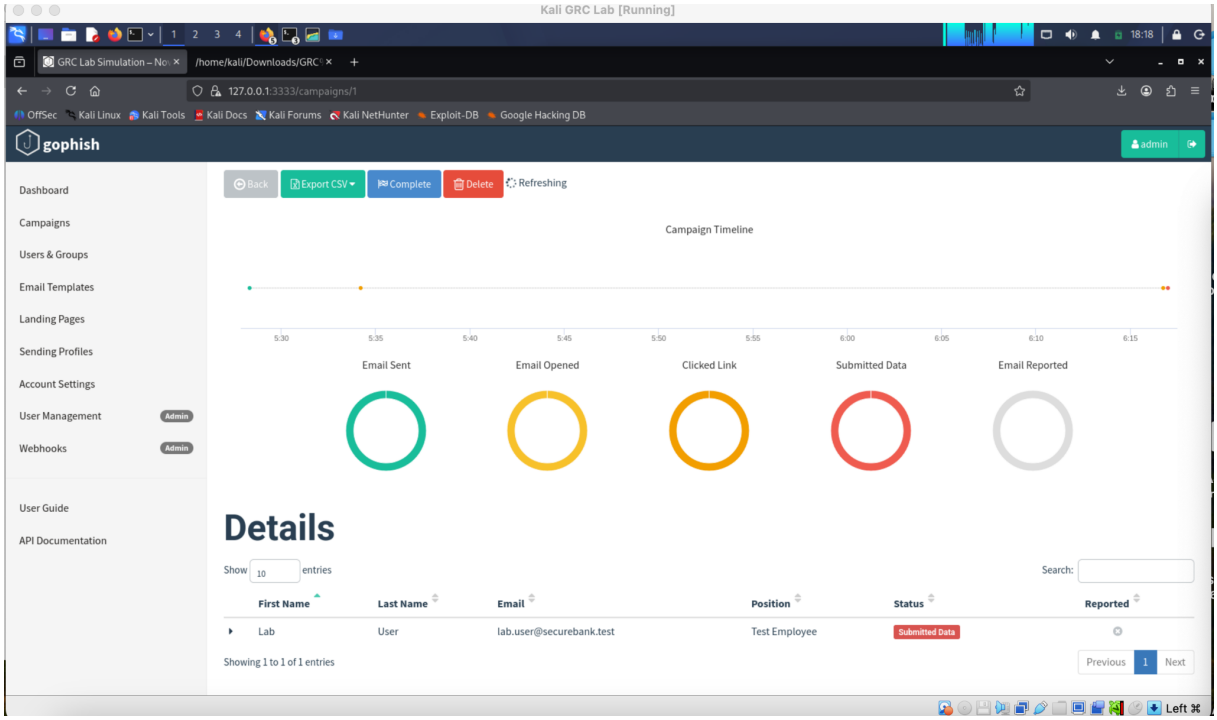


Figure 2. Final recipient detail: the fictional test recipient is marked “Submitted Data”. The dashboard counters were refreshing in this capture, so the final event count is corroborated by the recipient status rather than the blank circles.

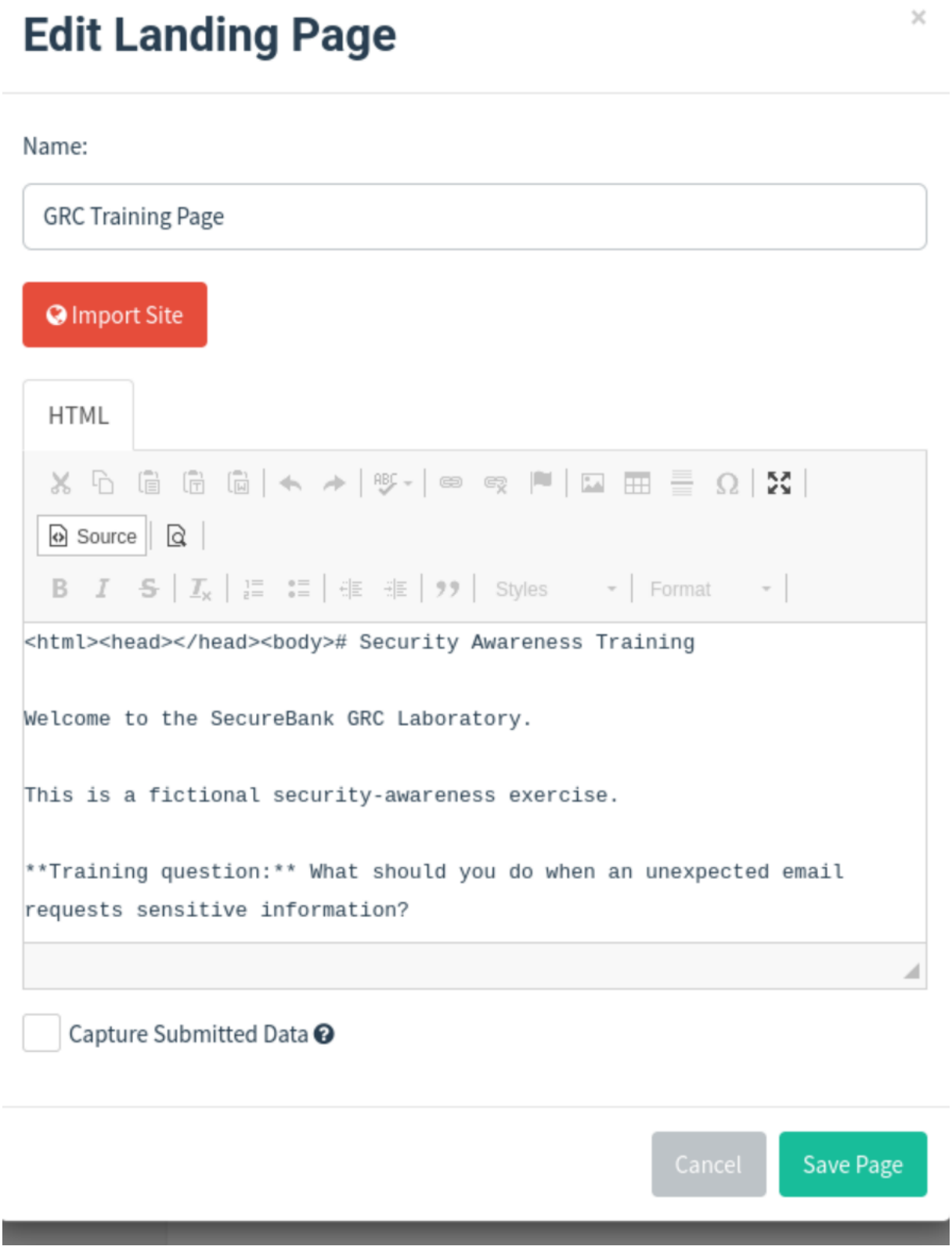


Figure 3. Landing-page configuration. The "Capture Submitted Data" checkbox is visibly unchecked; password capture was not enabled.

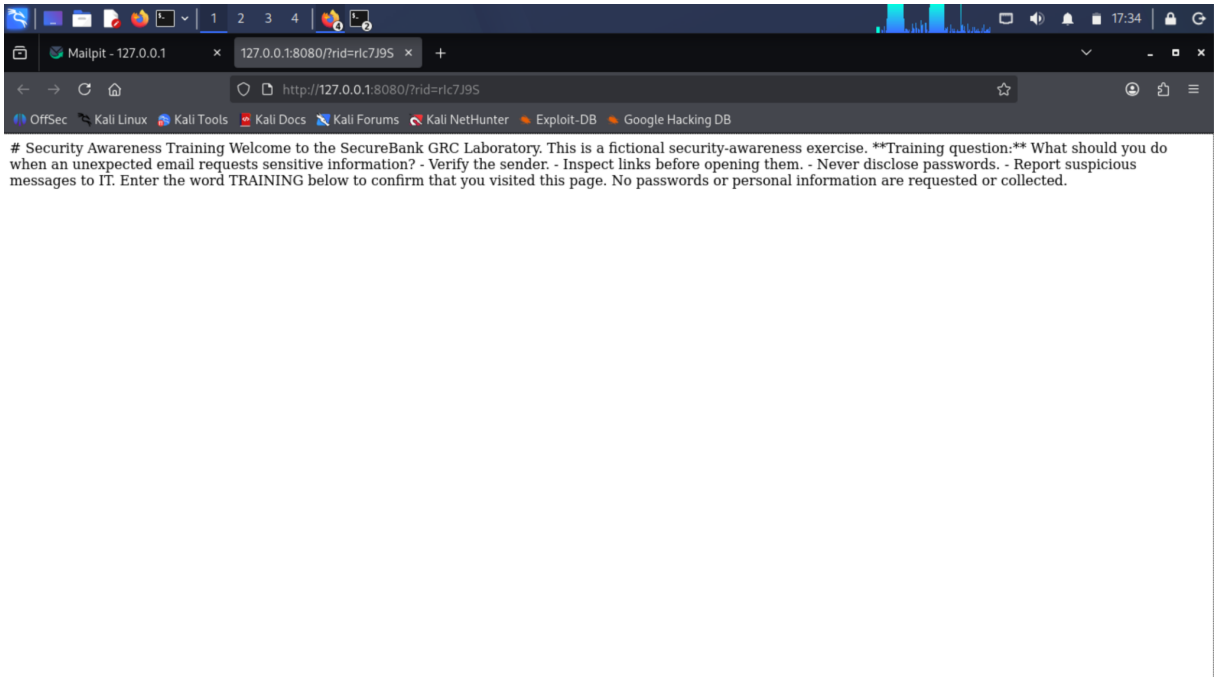


Figure 4. Fictional SecureBank GRC training page presented after the test link was opened. The page instructs the user to enter only the word TRAINING and not to provide passwords or personal information.

Appendix B – Submission Evidence Checklist

- GoPhish campaign results dashboard screenshot included.
- Recipient-level “Submitted Data” status screenshot included.
- Landing-page configuration evidence included, showing submitted-data capture unchecked.
- Fictional training-page evidence included.
- Risk assessment table and calculation methodology included.
- Executive summary, limitations and management recommendations included.